

[별표 2] 정보보안 점검표

2.1. 정보보안 기본활동

순번	세부 점검사항	비고
1	기관 자체 실정에 맞는 정보보안업무 내규를 수립하고 있는가?	
2	매년 정보보안업무 활동계획을 수립·시행하고 심사분석 하는가?	
3	정보보안업무 전담 조직 및 직원(정보보안담당관)이 지정되어 있는가?	
4	소속·산하기관 대상 정보보안 감사·점검·지도방문을 실시하는가?	
5	소속·산하기관 대상 정보보안 교육을 실시하고 있는가?	
6	사이버보안진단의 날을 내실 있게 수행하는가?	
7	정보보안 사고, 정보통신망 장애 발생시 보고체계 및 조치절차가 있는가?	
8	정보시스템 사용자에게 대한 심사 등 인적보안 절차·방법을 강구중인가?	
9	보직변경 등 인사이동시 정보시스템 접근권한을 신속하게 조정하는가?	
10	서버·PC 등 정보시스템 현황을 제대로 파악하는가?	
11	정보통신장비(노트북 등) 반출입 통제를 철저히 하는가?	
12	업무자료를 상용 전자우편으로 전송하고 있지 않는가?	
13	정보통신망 구축 및 유지보수 업무를 수행하는 외부인력에 대한 신원확인 및 보안서약서 징구 등 충분한 보안조치를 하고 있는가?	
14	용역업체 직원의 내부 정보시스템 접근을 통제하고 있는가?	
15	홈페이지에 자료 게재시 자체 보안성 검토를 시행하고 있는가?	
16	중요 정보화사업에 대하여 국가정보원에 보안성 검토를 의뢰하는가?	
17	정보보호시스템(암호모듈 포함) 도입시 보안적합성 검증절차를 준수하는가?	
18	비밀을 전자적으로 처리할 경우 국가용 보안시스템으로 암호화하는 등 규정을 준수하는가?	

2.2. PC 및 서버 보안관리

순번	세부 점검사항	비고
1	PC·서버에 설치된 운영체제 및 응용프로그램을 최신 보안업데이트 하였는가?	
2	백신프로그램이 자동 업데이트되고 실시간 감시기능이 설정되어 있는가?	
3	인터넷 PC에 업무관련 자료(비밀 포함)을 보관하고 있는가?	
4	업무용 PC에 비밀이 평문으로 저장되어 있는가?	
5	P2P, 웹하드, 메신저 등 업무에 무관한 서비스가 허용되거나 비인가 프로그램을 사용하지 않도록 보안조치 하는가?	
6	비인가자 접근방지를 위하여 PC 부팅 비밀번호를 설정했는가?	
7	서버내 저장자료는 중요도에 따라 권한설정이 되어 있는가?	
8	공개서버가 DMZ 구간에 위치하는 등 정보통신망 구성측면에서 PC 및 서버 등의 위치가 적정한가?	
9	인가받지 않은 휴대용 저장매체(USB메모리, 이동형 하드디스크, 메모리카드 등)를 반입·휴대하고 있는가?	
10	전자우편 비밀번호 설정시 특수문자 포함, 9자리 이상으로 설정하고 주기적으로 변경 사용하는가?	
11	비밀은 비밀용 USB메모리를 별도 지정하여 보관하고 비밀관리기록부에 등재하여 사용하고 있는가?	
12	서버 등 정보시스템 접근기록을 유지 관리하는가?	
13	PC·서버에 비인가 USB메모리 등 비인가 정보통신기기 연결시 작동되지 않도록 보안 설정되어 있는가?	
14	PC·노트북 등 저장매체가 있는 기기의 고장시 저장된 자료의 완전 삭제를 확인하고 외부에 수리를 의뢰하는가?	
15	중요정보가 저장된 매체 불용처리시 전용 소자장치로 삭제하거나 파쇄·융해 등 물리적으로 완전 파기하고 있는가?	

2.3. 네트워크 보안관리

순번	세부 점검사항	비고
1	정보시스템 세부 구성도(IP 포함)를 최신으로 유지하면서 대외비 이상 비밀로 관리하고 있는가?	
2	업무자료를 소통하기 위한 내부망은 인터넷과 분리 운영하는가?	
3	업무망·인터넷간 자료공유 방안이 적정한가?	
4	업무자료를 소통하기 위한 내부망 구축시 사설주소체계(NAT)를 적용하는가?	
5	국가정보원장이 안전성을 검증한 정보보호시스템을 운용하고 있는가?	
6	네트워크를 통한 파일공유를 제한하고 있는가?	
7	스위치·라우터 등 네트워크 장비와 서버는 비인가자가 접속 못하도록 IP·MAC통제 등 보안설정하고 불필요한 서비스포트를 제거하는가?	
8	와이브로, 무선랜 등 허가받지 않은 인터넷 접속경로가 존재하는가?	
9	첨단 정보통신기기에 의한 내부 업무자료 유출방지 대책이 충분한가?	
10	시스템 최초 설치시 등록된 관리자계정(회사명 등)·패스워드를 변경하였는가?	
11	장비 신규 도입, IP할당내역 등 전산망 구성 변동시 관련사항을 기록하는가?	
12	중요업무 처리 PC는 인터넷 연결을 금지하고 이상 유무를 수시로 점검하는가?	
13	무선네트워크 구축시 사전에 국가정보원의 보안성검토를 받았는가?	
14	홈페이지에 대한 보안취약점을 주기적으로 점검하는가?	
15	불가피한 사정상 무선중계기를 설치하였을 경우 WPA2이상 보안설정을 하였는가?	
16	직원의 재택·파견·이동근무 등 원격근무시 보안관리 절차가 충분한가?	
17	제어시스템을 독립망으로 운영하는가?	
18	(제어정보를 OA망으로 전달할 경우) 제어망 → OA망으로 일방향 통신을 하는가?	

2.4. 정보통신시설보안 및 대도청 활동

순번	세부 점검사항	비고
1	제어시스템이 인터넷과 분리 운영되는 등 제어정보망 보안관리가 양호한가?	
2	주요정보통신기반시설의 보안취약점을 주기적으로 분석·평가하는가?	
3	주요정보통신기반시설 취약점 분석·평가 세부결과를 중요자료로 관리하는가?	
4	인위적·자연적 원인에 따른 정보통신망 장애 대비 백업 등 재난방지 대책을 강구하였는가?	
5	통합전산센터, 정보통신실 등 중요 정보통신시설을 보호구역으로 관리하는가?	
6	사무실 책상서랍 등에 비밀문건이나 비인가 정보통신기기가 방치되어 있는지 주기적으로 확인하는가?	
7	외부인의 정보통신실 출입이 통제되고 관련기록이 관리되는가?	
8	무정전 전원공급장치 설치 등 비상시 전력장애에 대한 대책을 강구하고 있는가?	
9	침입자동 경보장치, CCTV 등 보안장비와 방화장비(하론소화기 등) 정상동작 여부를 정기적으로 점검하고 있는가?	
10	정보통신시설에 관련시스템 긴급 파기를 위한 장비(해머 등)를 비치하였는가?	
11	정보통신시설에 대한 접근권한을 업무목적에 따라 차등 적용하고 있는가?	
12	외부인이 청사내 출입할 경우 출입통제를 실시하고 있는가?	
13	주기적으로 대도청 측정활동을 실시하는가?	
14	통신(전화 등)단자함에 시건장치를 하여 비인가자가 무단 접근할 수 없도록 조치되어 있는가?	
15	중요 정보통신장비 수리·점검시 정보보안담당관이 입회하고 있는가?	
16	중요한 회의에는 무선전화기, 무선마이크, 인터콤 등 도청에 취약한 무선 통신 기기 사용을 통제하고 있는가?	

2.5. 암호장비·논리, 보안자재 관리

순번	세부 점검사항	비고
1	암호장비·논리, 보안자재 등을 소통 기준에 맞게 운용하고 있는가?	
2	암호장비·보안자재의 보유현황 및 동작 상태를 주기적으로 확인하는가?	
3	‘국가용 보안시스템 점검기록부’를 비치, 월1회 이상유무를 기록하고 정보보안 담당관은 점검여부를 확인하고 있는가?	
4	암호장비·보안자재의 정·부책임자 교체시 인계인수를 실시하고 국가용 보안 시스템 관리기록부에 인계인수 사항을 기록하는가?	
5	암호실은 출입을 통제하고 그 내용을 기록 유지하고 있는가?	
6	암호장비·보안자재는 취급책임자가 직접 운반하고 이를 확인하기 위하여 국가용 보안시스템 증명서를 사용하고 있는가?	
7	암호장비의 암호체계, 키 운용체계 관련서류 등 결과물을 비밀로 관리하는가?	
8	암호장비의 고유명칭, 제원 및 대상국소, 수량 등 운용현황이 기록된 문서는 대외비 이상으로 분류 관리하는가?	
9	노후 등으로 사용하지 않는 암호장비를 방치하고 있지는 않는가?	
10	未승인 보안제품이나 외국에서 생산한 보안제품을 무단 사용하는가?	
11	암호장비 설치시 분실·도난 등 보안사고 방지대책을 강구하고 있는가?	
12	암호장비가 설치된 랙 덮개는 시건장치를 하고 잠금 여부를 수시로 확인하는가?	
13	암호장비 설치 후 30일 이내에 국가정보원장에게 암호장비 운용현황을 등록하는가?	
14	보안자재 취급이 필요한 자에 대하여 암호자재 및 음어자재 취급을 인가하고 관련 업무 수행자는 인감등록을 실시하는가?	
15	암호자재는 암호실내 금고, 음어·약호자재는 시건된 별도함에 보관하는가?	
16	현용을 제외한 미래용, 사용완료 보안자재는 봉인하여 보관하고 있는가?	
17	사용기간이 만료된 보안자재는 국가정보원과 협의하여 처리하고 있는가?	
18	암호논리 적용시 국가정보원장이 안전성을 검증한 것을 사용하는가?	
19	암호취급자는 정보시스템 등에 암호논리를 적용하는 쏠 과정을 감독하고 용역 업체 등에 대해서는 보안서약서 징구 등 보안대책을 강구하는가?	

2.6. 보안관제 등 해킹 대응활동

순번	세부 점검사항	비고
1	사이버공격에 대응하기 위한 관제센터를 운영하거나 同 업무를 他기관에 위탁 하였는가?	
2	보안관제센터 운영을 총괄 관리하는 전담 공무원이 있는가?	
3	사이버공격 탐지·대응 매뉴얼이 구비되어 있는가?	
4	해킹사고 조사결과, 보안위규자에 대한 처벌이 제대로 이루어지고 있는가?	
5	보안시스템 및 정보시스템에 대한 로그를 일정기간 유지하고 있는가?	
6	보안관제 용역업체 직원에 대한 보안대책이 있는가?	
7	자체 DDoS공격 대응매뉴얼을 구비하였는가?	
8	자체 사이버위기 대응 모의훈련을 주기적으로 실시하는가?	
9	DDoS공격 등 침해사고 발생시 국가정보원 등 유관기관에 즉시 연락하는가?	
10	시스템 장애시 유지보수 업체에 연락할 수 있는 비상연락체계가 구비되어 있는가?	
11	보안관제시스템에 대한 물리적인 보안대책을 준수하고 있는가?	
12	침해사고 발생시 사고조사내역 등 관련 문서(전자문서 포함)를 저장하고 있는가?	
13	해킹메일 대응방안 등 침해사고 대응절차 등을 보안교육을 수행하는가?	
14	보안취약점 발표시, 대상기관이나 담당직원에게 즉시 배포하는가?	
15	국가사이버안전센터 등과 사이버위협정보, 탐지기술 등 정보를 공유하고 있는가?	
16	사이버공격 발생시 소속·산하기관에 전파할 수 있는 체계가 구비되었는가?	